

API Security with Tyk: Rate Limiting in Tyk

Learn how to control how often clients can call your APIs to prevent abuse, ensure fair usage, and protect backend systems.

Rate-Limiting

- A rate limit is a short-term restriction on the number of requests an API client can make to an API
- Defined as a number of requests over a number of seconds
- Exceeding the rate limit results in the request being blocked
- Can be applied in three ways, to suit different needs:
 - Keys, for individual rate limits
 - Policies, for centralised control of rate limits across many Keys and APIs
 - APIs, for aggregated rate limits across all API clients

Rate-Limiting

- Key and Policy configuration is via the `rate` and `per` properties:
 - `rate` is the number of requests
 - `per` is the number seconds
- Per-API rate limits can also be defined, with separate `rate` and `per` properties for each API, stored within the `access_rights` section
- API Definition configuration uses the same properties, but stores them within the `global_rate_limit` property:
 - `global_rate_limit.rate` and `global_rate_limit.per`

Rate-Limiting

- Rate limiting can be disabled in two ways:
 - Via the API definition: Set `disable_rate_limit` to true to disable rate limiting for all requests for the API
 - Via the Key or Policy: Set rate to a value less than 1 to disable rate limiting for the individual Key or all keys related to the Policy
- If either of these conditions is set then the related requests will no be subject to rate limiting

Rate-Limiting

- Rate limit calculation is based on the datetime of the request:
 - Previous requests within the rate limit period are totalled
 - If total exceeds the maximum allowed in the period, the request is blocked
- API clients which exceed the rate limit receive this response:
 - HTTP status code: 429 Too Many Requests
 - Body: `rate limit exceeded`

A Tyk 'rate limit exceeded' system event is also triggered

Rate-Limiting

For situations where a rate limit is defined on both a Key/Policy and also the API Definition:

- If the request causes any of the various rate limits to be exceeded, the Gateway will block the request
- This means that an API client may be within their Key/Policy rate limit, but if their request causes the API Definition's global rate limit to be exceeded, then the request is blocked